

Política Audit Log — AMS / Mageam

SF-660 · reunión VSC 2026-05-11 · approver: Magdalena Ortega / Jorge Alquinta

1. Alcance

El audit_log registra TODA acción crítica sobre entidades de negocio del sistema, sin excepciones. Es la fuente única de trazabilidad para cumplir requisitos de auditoría externa (SAP PM compliance + ISO 55000) y defensa-en-profundidad ante incidentes.

2. Entidades cubiertas

Entidad	Acciones registradas
work_request (Aviso)	CREATE · UPDATE · APPROVE · REJECT · CANCEL · IA_SUGGESTION_ACCEPT · IA_SUGGESTION_REJECT
managed_work_order (OT)	CREATE · UPDATE · TRANSITION (cada cambio de estado: CREADO→LIBERADO→PLANIFICADO→EN_PROGRAMACION→PROGRAMADO→EN_EJECUCION→CERRADO/CANCELADO) · NOTIFY_PARTIAL · CLOSE · REOPEN
operations	UPDATE (cantidad/hours/specialty changes via update_work_order)
materials	UPDATE · RESERVE · CONSUME
support_equipment	UPDATE · ADD_TO_CATALOG
user	LOGIN · LOGOUT · CREATE · UPDATE_ROLE · DEACTIVATE · ACTIVATE · MFA_ENROLL
settings	UPDATE
backlog	CREATE · OPTIMIZE · APPROVE
weekly_program	RESERVE_WEEK · REPROGRAM
criticality_assessment	CREATE · APPROVE
fmeca_worksheet	CREATE · UPDATE · APPROVE
rca	CREATE · UPDATE_STATUS
dms_documents	UPLOAD · DELETE

3. Detalle mínimo por entrada

Cada fila de audit_log debe tener:

Campo	Tipo	Ejemplo	Obligatorio
`audit_id`	UUID	`a1b2c3...`	✓
`timestamp`	ISO8601 UTC	`2026-05-11T14:32:18.234Z`	✓
`entity_type`	string	`managed_work_order`	✓
`entity_id`	string	`WO-...`	✓

`action`	string	`TRANSITION`	✓
`user`	string	`61e2c595-...`	✓ (o `Agent/IA` + confirmar)
`payload`	JSON	{`old_status`, `new_status`}	✓ para UPDATE/TRANSITION
`ip`	string	`172.23.0.1`	✓ para LOGIN
`user_agent`	string	`Mozilla/5.0...`	✓ para LOGIN
`plant_id`	string	`GOLDFIELDS-SN`	recomendado para filtrado

Acciones del agente IA: campo `user` = `agent:<agent_id>` ; campo `payload.confirmed_by` = `user_id` humano que aceptó la sugerencia (cuando aplique). Si la acción es totalmente autónoma (ej. Al Vision sin confirm), `payload.autonomous = true` .

4. Retención

- **2 años activos** en BD principal (consulta directa con filtros).
- **5 años en archivo** (export semanal CSV/Parquet → S3 / blob storage cold).
- **>5 años:** política configurable; por default eliminación con notificación previa al stakeholder.

Razones para 5 años: alineado con (a) Plan Matriz minero típico de 5 años, (b) requerimientos típicos de auditoría SAP, (c) demanda histórica de RCA tras eventos críticos.

5. Acceso

Rol	Vista	Filtros	Export
admin	Todo	Sí	Sí (CSV/PDF)
manager	Todo	Sí	Sí (CSV/PDF)
supervisor	Su planta + propias acciones de OTs que supervisa	Sí limitado	No
planner	Sus propias acciones + OTs que planificó	Limitado	No
engineer	RCA + FMECA + acciones propias	Limitado	No
tecnico	Sus propias acciones (read-only)	No	No

Implementación actual: `/admin/audit-log` requiere `admin` o `manager` (`require_role("admin", "manager")`). Para supervisor/planner/tecnico necesitamos endpoint scoped que filtre por `user_id == requesting_user.user_id` o `entity_id IN owned_entities` .

6. Inmutabilidad

- **Sin endpoint UPDATE ni DELETE** sobre `audit_log`. Inserciones append-only.
- Tests automáticos verifican que no exista `db.delete(AuditLogModel)` ni `db.execute("DELETE FROM audit_log")` en código de aplicación. Solo el script de purga nocturna (>5 años) puede eliminar.

- Cualquier corrección a un evento mal registrado se hace agregando un nuevo evento `CORRECTION` que apunta al `audit_id` original vía `payload.corrects = "..."`.

7. Acciones del agente IA — política específica

- `user = "agent:<agent_name>"` (ej. `agent:wr-classifier`, `agent:vision-equipment-id`, `agent:scheduling-optimizer`).
- Si la acción requiere confirmación humana (priority bump, equipment match, scheduling), guardar TAMBIÉN el `confirmed_by`:

```
```json
{ "user": "agent:vision-equipment-id", "action": "EQUIPMENT_MATCH",
 "payload": { "ai_choice": "PUMP_03", "confirmed_by": "61e2c595-..." } }
```
```

- Si es autónoma (sin confirmar): `payload.autonomous = true`. Estas requieren revisión semanal por admin.

8. Errores backend/frontend

Separado del `audit_log` de negocio:

- Backend: Python `logging` → `stdout` (capturado por `docker logs ocp-backend`); errores `≥WARNING` también persistidos en `error_log` (a definir).
- Frontend: Sentry (`@sentry/react` ya integrado). DSN configurado por env.

Política de error log: TTL 90 días + alertas para errores recurrentes (mismo stack trace `≥5` veces en 24h).

9. Criterios de aceptación verificación

| Criterio | Estado actual |
|--------------------------------|---|
| Cada acción crítica registrada | ■ implementado en <code>`audit_service.log_action()`</code> invocado en 30+ puntos del backend |
| Sin acciones huérfanas | ■■■ verificar — algunos <code>UPDATEs</code> no llaman a <code>`log_action`</code> (auditar) |
| Endpoint paginado con filtros | ■ <code>`/admin/audit-log?entity_type=&action=&user=&start=&end=&limit=&offset=`</code> |
| UI Audit Log | ■ <code>`/audit-log`</code> (admin/manager) |
| Tests inmutabilidad | ■ pendiente test que falle si encuentra <code>`DELETE FROM audit_log`</code> en código no autorizado |
| Acceso por rol | ■■■ implementación binaria (admin/manager sí, resto no) — falta <code>scoped supervisor/planner</code> |

10. Pendientes

- `[]` Test automático: `grep` en codebase de `DELETE FROM audit_log` fuera de `scripts/purge_audit_log_5y.py` (a crear) — debe fallar el test

- [] Endpoint scoped audit-log para supervisor/planner (su planta + sus acciones)
 - [] Script `scripts/purge_audit_log_5y.py` con `--dry-run` por default
 - [] Cron mensual de export `audit_log_archive_YYYY-MM.csv` a S3
 - [] Tabla `error_log` para errores recurrentes backend
-

Aprobación: stakeholder + dev lead. Fecha: 2026-05-11. Owner: David Cabezas (VSC).